

s2.06 — Regional PKI disaster recovery — backup / restore and continued data-plane operation

Index

- [Interview framing](#)
- [Requirements — IC3 baseline](#)
- [Capacity and consequence — IC3 baseline](#)
- [Architecture and flow — IC3 baseline](#)
- [API and data model — IC3 baseline](#)
- [Recovery point and restore verification — IC3 baseline](#)
- [Fenced promotion and failback — IC3 baseline](#)
- [Failure, operations, and security](#)
- [Alternatives and IC4 stretch](#)
- [Level signal — IC3 baseline vs IC4 stretch](#)
- [Interview pushback and validation](#)
- [Recall card](#)
- [References](#)

Interview framing

- Target: OCI IC3 ownership of a bounded platform component.
 - `IC3 baseline` is what must land in every phase.
 - `IC4 stretch` adds architecture changes under stronger constraints.
 - These are preparation labels, not Oracle's official rubric.
- Evidence: JD resilience requirements
 - Prep addition, recorded in [the bank](#).
 - The architecture below is a proposed interview answer.
 - It does not claim to reproduce Oracle's implementation or an interviewer's accepted answer.
- Why this is hard
 - Naive: nightly database dump to object storage, plus a DNS switch to a standby region when the primary is lost.
 - First break: the dump restores metadata, but the CA private keys live in an HSM and are not in the dump, so the restored CA cannot sign.
 - Second break: the old region comes back unfenced and two regions sign under one CA, or a restored revocation table older than the last published CRL un-revokes a certificate.
 - Minimum primitives
 - A coordinated recovery point
 - A restore test that gates `READY`
 - An independent fencing authority with a monotonic writer epoch
 - Consumers that keep handshaking on cached chains.
- 🗨️ “A recovery point must recover the keys, preserve acknowledged revocations, and fence the old signer.”
- Opening script
 - “I will treat this as control-plane recovery for a regional certificate service whose data plane must stay statically stable.”
 - “First I confirm scope, RPO and RTO, and where the CA keys live, because key custody decides whether a backup is a recovery point at all.”
 - “Then I define the recovery point as a coordinated cut: database position, artifact hashes, key inventory, revocation watermark, serial ledger, and audit checkpoint.”

- “The deep dives are restore verification that gates `READY`, and fenced promotion with a writer epoch so a restore can never enable two issuers.”
- “I will close with failback reconciliation, the failure table, and where per-region subordinate CAs change the design.”

Phase	Clock	Deliverable
Intro and behavioral slice	00:00–05:00	90-second pitch; confirm the prompt
Requirements	05:00–11:00	Scope, RPO/RTO, key custody, primary invariant
Estimates and contract	11:00–17:00	Data volume, replication lag, RTO budget; recovery API
Architecture	17:00–30:00	Diagram, ownership, one promotion trace
Deep dive	30:00–45:00	Recovery point verification; fenced promotion and failback
Operations and tradeoffs	45:00–50:00	Failure table, drills, tradeoff, wrap script
Wrap-up	50:00–54:00	Four-sentence recap and weakest assumption
Questions for interviewer	54:00–60:00	Two role-specific questions

- Clock note
 - If the interviewer states 45 minutes, drop the intro to 2 minutes and compress each phase proportionally.
 - The interviewer's clock wins over this table.

Requirements — IC3 baseline

- Numerical targets are interview assumptions unless an adjacent primary source states otherwise.

Question	Assumed answer	Why it changes the design
Scope?	The <code>s2.01</code> regional service: CAs, cert versions, CRLs, audit, plus the Vault/HSM keys they reference	Keys and metadata have different custody; the point must span both
Failure model?	Whole-region loss, plus in-region metadata-store loss	Regional loss needs a standby region; in-region loss needs multi-AD replicas only
RPO and RTO?	Metadata RPO 5 min; security-intent RPO 0; issuance RTO 2 h	Separate availability costs and loss contracts
Where do CA keys live?	HSM-backed keys in a Vault; the service holds handles only	The standby needs a vendor-supported protected key path or its own subordinate key
How do consumers get chains?	LBs and sidecars pull bundles and cache them on disk	Handshakes never call the control plane; continuity is a cache property
Emergency revocation during DR?	Yes, within 1 h	The standby must sign a CRL before it may issue anything

- Functional scope
 - Capture coordinated recovery points on a schedule and on demand.
 - Verify a point by an isolated restore test before publishing it as `READY`.
 - Promote a standby region to the single active writer for a service scope, fencing the previous writer independently of DNS.
 - Keep handshakes, chain fetches, and CRL fetches working through the whole event.
 - Fail back with reconciliation, then a second fenced promotion.

Requirement	Target	Enforced by
Ordinary metadata RPO	≤ 5 min	Continuous log shipping; pause affected writes if the promised RPO cannot be maintained
Acknowledged security-intent RPO	0	Commit revocation and pre-signing intent outside the regional failure domain before acknowledgment or signing
Issuance RTO	≤ 2 h from declaration	Warm standby with data pre-restored; runbook budgeted per step

Requirement	Target	Enforced by
Handshake continuity	0 control-plane-induced failures for surviving consumers with > 2 h remaining required validity	Persisted keys/chains and fresh acceptable status; excludes servers lost with the region
Chain and CRL fetch availability	99.99% during DR	Object storage plus CDN, replicated to the standby
Emergency revocation during DR	≤ 1 h to a published CRL	Standby signs CRLs with a recoverable key before issuance opens
Recovery point freshness	New READY point every 24 h	Capture job plus restore test; stale-point alarm
Writer exclusivity	Exactly 1 writer per service scope	Fencing epoch checked on every write and sign

- Invariants
 - READY requires verified identity and custody for every referenced version, with challenge signatures only for authorized usable signers.
 - The writer epoch is monotonic per service scope and lives outside both regions
 - A restore never lowers it.
 - Revocation is monotonic: no promotion or failback may turn a revoked serial back into good.
 - Serials are unique per CA across every writer epoch.
 - Metadata backups hold public material and key handles.
 - Separate vendor-protected key backups contain recoverable wrapped material, never plaintext private keys.
- Non-goals
 - Active-active issuance from two regions for one CA.
 - Zero-RPO for issuance metadata.
 - Recovery of consumer-held leaf private keys.

Capacity and consequence — IC3 baseline

- Data volume
 - 1M leaves, about 3 retained versions, about 4 KB PEM chain each: about 12 GB of rows.
 - Audit at 20k events/day and 1 KB each: about 20 MB/day, about 50 GB over 7 y.
 - Decision: base snapshot plus shipped log, not nightly dumps
 - Copying 12 GB at 100 MB/s is about 2 min, so replay and verification own the clock.
- Change rate and RPO
 - 16k renewals/day is about 0.2/s
 - A 5 min RPO bounds loss to roughly 60 issuance events.
 - Those certificates are signed but absent from the restored metadata: orphans.
 - Decision: promotion reconciles orphans from the audit checkpoint
 - Short leaf TTL bounds the unrevocable window.
- Consumer fetch during failover
 - 10k services fetching hourly is about 3/s
 - A 60 s DNS TTL plus fleet-wide refresh yields a burst on the order of 170/s.
 - Decision: bundles and CRLs sit on replicated object storage behind a CDN with ETags
 - The API fleet never serves the fetch path.
- RTO budget
 - Detect 10 min, decide 15 min, verify keys and replay tail 30 min, fence and promote 10 min, converge consumers 30 min: about 95 min.
 - Key verification: about 2k CA keys at 50 ms per test signature is 100 s serially, seconds in parallel.
 - CRL nextUpdate is 24 h
 - A 2 h DR expires nothing, a 48 h outage without a signer breaks every hard-fail verifier.

- Decision: the RTO is verification-bound, so the standby must hold restored data and a usable CRL signer before the incident.

Architecture and flow — IC3 baseline

```

Primary API -> ordinary metadata DB ----async----> warm standby DB
    |
    +-> independent security ledger [revocations + pre-signing intents]
    |         | synchronously durable outside regional loss domain
    v         v
signing broker <- independent writer-grant authority
    |
selected HSM key versions ---vendor-protected recovery---> standby HSM

Artifacts by hash -> replicated object storage / CDN -> surviving consumers
                                                         local keys + chain
                                                         valid status evidence
Restore verifier -> point manifest + key evidence + security watermark

```

- Recovery coordinator owns recovery points.
 - Mechanism bought: one coordinated cut across database position, artifact hashes, key inventory, revocation watermark, serial ledger, and audit checkpoint.
 - Cost: a multi-store capture protocol
 - A point is unusable until a restore test passes.
- Fencing authority owns the writer epoch.
 - Mechanism bought: a quorum outside both regions hands out a monotonic epoch and a lease
 - The issuer refuses to write or sign without it.
 - Cost: one more consensus dependency
 - If unreachable, the current writer continues only until its lease expires.
- Vault/HSM owns key custody.
 - Mechanism bought: private keys never leave the HSM boundary
 - The standby gets them only through the vendor's protected backup or replication path.
 - Cost: key recoverability is a separate authorization and verification step
 - A database restore says nothing about it.
- Replicated artifact store owns bundles and CRLs.
 - Mechanism bought: immutable blobs by hash, so the restored region can verify what was actually published.
 - Cost: cross-region lag must be measured
 - The point records hashes, not "latest".
- Consumers own data-plane continuity.
 - Mechanism bought: full chain and key on disk, refreshed by interval or event with ETag
 - Handshake code never blocks on the control plane.
 - Cost: cache on boot is the defeater
 - A consumer with no local copy dies unless last-known-good ships in the deploy artifact.

→ Primary is declared lost; on-call opens a promotion with the newest `READY` point and `expectedWriterEpoch = e`.

→ Fencing authority compares-and-sets `writer_epoch = e + 1`, `writer_region = standby`; the old lease is invalid everywhere.

→ Standby replays the shipped log tail to the recorded position and compares artifact hashes with the replicated store.

→ Standby proves each referenced key version with a test signature verified against the CA certificate's public key.

→ Standby unions the last published CRL per issuer into restored revocations; `crl_number` continues above the published one.

- Standby publishes a fresh CRL and bundle set, then enables issuance under epoch `e + 1`.
- Consumers keep handshaking on cached chains throughout and pick up the new endpoint on their next refresh.
- The promotion operation reports `SUCCEEDED` with `newEpoch`, checks, and orphan serials flagged for follow-up.

API and data model — IC3 baseline

Surface	Contract	Conflict/error behavior
POST <code>/v1/recovery-policies</code>	<code>{resourceScope,rpoTarget,rtoTarget,targetRegion}</code> ; 201 policy	I; targets are validated by drills, not guaranteed by a setting
POST <code>/v1/recovery-points</code>	<code>{policyId}</code> ; 202 <code>{operationId}</code>	I; duplicate key replays the same operation
GET <code>/v1/recovery-points/{id}</code>	<code>{state,throughPosition,keyInventory,artifactManifest,verifiedAt}</code>	READY only after an isolated restore test; CAPTURED otherwise
POST <code>/v1/restore-tests</code>	<code>{recoveryPointId,isolatedTarget}</code> ; 202 operation	I; target has no production signing or traffic authority
POST <code>/v1/regional-promotions</code>	<code>{targetRegion,recoveryPointId,expectedWriterEpoch}</code> ; 202 operation	I; epoch mismatch 409; fencing precedes any restore side effect
GET <code>/v1/regional-promotions/{id}</code>	<code>{state,newEpoch,checks,errors}</code>	Checks visible before issuance is enabled
POST <code>/v1/regional-failbacks</code>	<code>{targetRegion,expectedWriterEpoch}</code> ; 202 operation	I; reconcile divergence, then a second fenced promotion

State	Key	Fields/invariant
Recovery point	<code>(tenant_id, point_id)</code>	<code>db_position</code> , <code>artifact_manifest_ref</code> , <code>key_inventory_ref</code> , <code>revoked_through_generation</code> , <code>serial_ledger_ref</code> , <code>audit_checkpoint</code> , <code>state</code> , <code>verified_at</code>
Regional promotion	<code>(tenant_id, promotion_id)</code>	<code>target_region</code> , <code>point_id</code> , <code>old_epoch</code> , <code>new_epoch</code> , <code>state</code> , <code>checks</code> ; CHECK (<code>new_epoch > old_epoch</code>)
Fencing record	<code>(service_scope)</code>	<code>writer_region</code> , <code>writer_epoch</code> , <code>authority_lease</code> ; lives in the fencing authority, never in the snapshot
Key inventory	<code>(point_id, ca_id, issuer_version, key_version)</code>	Public-key fingerprint, expected key state, protected backup reference, and restore evidence
Consumer cache	local disk per consumer	Chain, key, signed trust generation, freshness limits; readable with no network call

- Reference DDL
 - Keys and uniqueness match the state table above and the [companion schema](#).
 - The fencing record and the consumer cache are deliberately not in this database
 - The fencing record lives in the independent fencing authority so a restore can never rewind the epoch.

- The consumer cache is a local file per consumer.

```
CREATE TABLE recovery_policies (
  tenant_id text NOT NULL, policy_id text NOT NULL,
  resource_scope text NOT NULL, target_region text NOT NULL,
  rpo_target_s integer NOT NULL, rto_target_s integer NOT NULL, -- requirements a drill validates, not
guarantees
  PRIMARY KEY (tenant_id, policy_id),
  CHECK (rpo_target_s > 0 AND rto_target_s > 0)
);
CREATE TABLE recovery_points (
  tenant_id text NOT NULL, point_id text NOT NULL, policy_id text NOT NULL,
  source_region text NOT NULL,
  db_position text NOT NULL, -- replay position; immutable after capture
  artifact_manifest_ref text NOT NULL, -- object-storage manifest of immutable blob hashes
  key_inventory_ref text NOT NULL, -- signed inventory document; rows below are its
projection
  serial_ledger_ref text NOT NULL, -- serial high-water marks per issuer
  revoked_through_generation bigint NOT NULL,
  audit_checkpoint text NOT NULL,
  state text NOT NULL, created_at timestampz NOT NULL,
  verified_at timestampz, restore_seconds integer, evidence_ref text, -- written by the restore test only
  PRIMARY KEY (tenant_id, point_id),
  FOREIGN KEY (tenant_id, policy_id) REFERENCES recovery_policies,
  CHECK (state IN ('CAPTURING', 'CAPTURED', 'READY', 'FAILED')),
  CHECK (state <> 'READY' OR (verified_at IS NOT NULL AND evidence_ref IS NOT NULL))
);
CREATE INDEX recovery_latest_ready ON recovery_points
  (tenant_id, policy_id, created_at DESC, point_id) WHERE state = 'READY';
CREATE TABLE point_key_inventory (
  tenant_id text NOT NULL, point_id text NOT NULL,
  ca_id text NOT NULL, issuer_version bigint NOT NULL, key_version bigint NOT NULL,
  public_key_fingerprint text NOT NULL, -- hash of the canonical public key
  expected_state text NOT NULL, -- lifecycle state at capture; restore must preserve it
  backup_ref text NOT NULL, -- protected HSM backup reference, never key bytes
  required_signer boolean NOT NULL, -- READY fails if this version cannot sign in the drill
  restore_evidence jsonb, -- challenge signature outcome
  PRIMARY KEY (tenant_id, point_id, ca_id, issuer_version, key_version),
  FOREIGN KEY (tenant_id, point_id) REFERENCES recovery_points,
  CHECK (expected_state IN ('ENABLED', 'DISABLED', 'PENDING_DELETION', 'COMPROMISED'))
);
CREATE TABLE regional_promotions (
  tenant_id text NOT NULL, promotion_id text NOT NULL, target_region text NOT NULL,
  point_id text NOT NULL, old_epoch bigint NOT NULL, new_epoch bigint NOT NULL,
  state text NOT NULL, checks jsonb NOT NULL, errors jsonb,
  started_at timestampz NOT NULL, finished_at timestampz,
  PRIMARY KEY (tenant_id, promotion_id),
  FOREIGN KEY (tenant_id, point_id) REFERENCES recovery_points,
  CHECK (new_epoch > old_epoch),
  CHECK (state IN ('ACCEPTED', 'RUNNING', 'SUCCEEDED', 'FAILED'))
);
CREATE INDEX promotions_by_region ON regional_promotions
  (tenant_id, target_region, started_at DESC, promotion_id);
```

- What the DDL does not capture
 - The fencing record (`service_scope`) → `writer_region`, `writer_epoch`, `authority_lease` is owned by the fencing authority; `old_epoch` and `new_epoch` are audit copies, never the source of truth.
 - Backup bytes, artifact blobs, and HSM key material live behind `backup_ref`, `artifact_manifest_ref`, and the HSM; the rows hold hashes and handles only.
 - Deviation from the companion
 - `recovery_policies` and `point_key_inventory` are added as parent and child of `recovery_points`.
 - The inventory key gains a `tenant_id` prefix so it stays tenant-scoped like every other table.
 - `serial_ledger_ref`, `audit_checkpoint`, `restore_seconds`, and `evidence_ref` are additions that carry the restore-test evidence.

- Conventions
 - I and 202 follow the [shared conventions](#)
 - Full DDL is in [#pki-6](#).
 - `expectedWriterEpoch` is compared against the fencing authority, never against the caller's own database.
 - Points are immutable after capture
 - Verification adds `verified_at` and `state`, never rewrites positions.

Recovery point and restore verification — IC3 baseline

- Recovery contracts
 - Ordinary resource metadata may lose at most 5 min under the proposed asynchronous RPO.
 - Acknowledged revocations require RPO 0 in an independently replicated security ledger.
 - Persist the issuance serial, issuer key version, and exact intent in that ledger before physical signing.
 - Full certificate metadata can remain asynchronous while the security intent remains recoverable.
 - If the ledger cannot commit outside the region's failure domain, stop accepting those security-sensitive operations.
- Recovery point contents
 - Database replay position and schema version.
 - Immutable artifact hashes and their covered ledger generations.
 - Inventory keyed by CA ID and issuer key version.
 - Public-key fingerprints and protected key-backup references.
 - Independent security-ledger checkpoint and recovery watermark.
 - Audit coverage and unresolved issuance intent IDs.
- Capture
 - Read inventories at a consistent database position.
 - Record hashes rather than mutable current pointers.
 - Publish CAPTURED until a restore drill verifies the complete point.
- Key recovery
 - This design selects HSM-protected CA keys.
 - OCI Vault also has software-protected key options
 - Do not generalize HSM custody to every Vault key.
 - Metadata backups contain handles and public material.
 - Separate vendor-protected backups or replication preserve recoverable key material without exporting plaintext private keys.
 - Select a supported vault type and restore target before accepting the DR design.
 - Current [OCI backup/restore constraints](#)
 - Vault backup supports virtual private vaults.
 - Key backup supports HSM-protected master encryption keys, not software-protected keys or secrets.
 - Restore retains the original tenancy and compartment requirements.
 - Cross-region restore needs policy and key-reference updates for the new OCIDs.
 - Restore updates are additive, so separately reapply current disable and revocation policy before serving.
- Isolated verification
 - Deny production traffic and ordinary signing in the restore cell.
 - Give a narrowly scoped drill identity permission for controlled challenge signing on usable key versions.
 - Preserve disabled or compromised key states instead of enabling every historical key to pass a test.
 - Validate custody and expected state for those versions through the supported recovery mechanism.

```

VERIFY(point):
  restore DB to point.position in isolated cell
  verify schema, artifacts by hash, and covered ledger checkpoint
  for each (CA, issuerVersion, keyVersion) in inventory:
    obtain the matching version's CA certificate and public key
    require hash(canonical public key) == inventory.publicKeyFingerprint
    verify restored key identity, attributes, and expected lifecycle state
    if authorized usable signer:
      challenge = domain-separated random drill challenge
      signature = restricted_drill_sign(exact keyVersion, challenge)
      verify signature using that version's public key and algorithm
    require every required production signer recoverable in its expected state
  persist READY, verifiedAt, measured restore time, and test evidence

```

- Readiness is evidence for a particular recovery point.
 - Revalidate the current security-ledger watermark at promotion time.
 - A daily successful drill alone does not prove the last minute's revocations survived.

Fenced promotion and failback — IC3 baseline

- Independent authority
 - Keep writer ownership and recovery epoch in a quorum outside either regional database snapshot.
 - The signing broker consumes current grants from that authority.
 - Old regional workers must not retain a direct unfenced HSM signing path.
 - Two separately restored databases checking only their own highest epoch cannot fence one another.
- Promotion order
 - CAS the intended writer epoch from e to $e+1$.
 - Revoke old grants and wait for all prior grants to expire with the declared clock allowance.
 - Confirm the old signing path can no longer authorize new work.
 - Replay metadata and independently committed security intents through the recovery watermark.
 - Verify key versions and current artifact hashes.
 - Publish fresh status from the recovered ledger before opening new issuance.
 - A physical signature already produced before the barrier remains an attributable prior-epoch attempt.
- Revocation continuity
 - Recover every acknowledged revocation from the independent ledger.
 - Union in later signed CRL evidence as an additional consistency check.
 - A last published CRL alone misses committed revocations that had not yet been published.
 - Continue CRL numbering above every known reserved and published number.
 - If the safe recovery watermark is unknown, do not issue new good status from an incomplete ledger.
 - Continue only still-valid cached status under its profile while recovery is blocked.
- Serial and intent continuity
 - Use the same issuer-scoped random serial policy as s2.01.
 - Recover signing intent before deciding whether a certificate is an orphan.
 - Record writer epoch on every attempt and committed certificate.
 - Signature replay for the same intent may reuse a serial without implying a generator collision.
 - Different TBS bodies using one issuer/serial are a security incident.
- Failback
 - Restore the repaired region from the active region's current state.
 - Merge revocations monotonically and reconcile all surviving issuance intents.
 - Quarantine or revoke uncertain signed intents according to policy.
 - Lost local audit data cannot reconstruct itself
 - That is why security intent is independently durable.
 - Use a second fenced promotion to $e+2$ after verification.
- Alternate issuer

- A pre-provisioned regional subordinate can reduce dependency on recovering one key.
 - Its chain and revocation endpoints must already be accepted by the required client cohorts.
 - It does not transparently replace a missing issuer for every existing certificate.
- A primary is partitioned but retains an unfenced HSM credential.
- ⇒ Moving DNS leaves it able to sign.
- Enforce the independent writer grant inside the only permitted signing path.
- Expire old grants before enabling the successor.

Failure, operations, and security

Failure	Blast radius	Detection	Degraded behavior	Recovery
Whole primary region lost	Issuance and revocation for its CAs	Probes from two other regions; replication heartbeat stops	Handshakes on cached chains; fetches from CDN	Fenced promotion from the newest <code>READY</code> point
HSM key version unrecoverable in standby	Every CA on that key	Restore test signature fails	Point stays <code>CAPTURED</code> ; stale- <code>READY</code> alarm	New subordinate key, cross-sign, redistribute chain
Replication lag exceeds RPO	Ordinary metadata writes	Lag above 2 min warning or 5 min bound	Pause affected writes at the hard bound; security intent remains independently durable	Restore replication before reopening; reconcile recorded intents
Old region returns unfenced	Duplicate writers for one CA	<code>fenced_write_rejected</code> counter	Old region read-only by construction	Restore it from the current point; second promotion
DNS failover without fencing	Split-brain issuance	Two regions report signing for one CA	None safe; this is the incident	Fence now, then reconcile as in failback
Restored revocation older than published CRL	Serials revoked after the watermark	Published <code>cr1_number</code> above restored watermark	Hold publication until union is done	Union last CRL; publish with higher <code>cr1_number</code>
Outage past CRL <code>nextUpdate</code>	Hard-fail verifiers reject everything	CRL age gauge	Soft-fail verifiers continue	Sign a fresh CRL from the standby before enabling issuance
In-region metadata store outage	New issuance in that region	Error rate, health check	Handshakes and fetches unaffected; renewals queue	In-region replica across ADs; no regional promotion
Consumer boots with empty cache	That consumer	Boot fetch fails	Consumer cannot serve	Last-known-good in the deploy artifact; cache on disk

- Observe
 - Replication lag and audit-checkpoint gap.
 - Age of the newest `READY` point
 - Restore-test duration and pass rate.
 - `fenced_write_rejected` and lease expiry events.
 - CRL age per issuer
 - Bundle fetch error rate by region.
 - Certificates expiring within `14 d`: the countdown clock during a long control-plane outage.
- Retry discipline
 - Capture and restore-test operations retry with exponential backoff and jitter under the same idempotency key.
 - Promotion never retries past a `409` epoch mismatch
 - A human confirms which writer is intended.
 - Key verification failures are terminal for that point

- They need a new key path, not another attempt.
- Tenant isolation
 - Points and promotions are scoped by tenant and compartment
 - One scope's promotion cannot move another tenant's writer.
 - Restore-test cells run under a policy denying production signing and traffic.
 - Documented OCI behavior: IAM policy statements are compartment-scoped
 - See [IAM policies](#).
- Rollout and rollback safety
 - Recovery-point schema changes follow expand, migrate, contract
 - A new coordinator reads points captured by the previous version.
 - Runbook changes are drilled in the isolated cell before production use.
 - Control-plane deploys never roll the data-plane fleet
 - Consumers survive on cached chains.

Alternatives and IC4 stretch

Option	What it is	Strength	Weakness	Choose when
Cold backup and rebuild	Periodic dumps; rebuild on loss	Cheapest	RTO hours to days; keys often missing	Dev and test only
Warm standby plus security ledger	Async ordinary metadata; independently durable security intent	Moderate metadata latency and recoverable revocation	Security operations depend on remote durability	Baseline with the stated monotonic-revocation invariant
Synchronous cross-region replication	Every commit waits for the standby	RPO 0 for metadata	Issuance coupled to two regions	Revocation events only, if RPO 0 is demanded there
Per-region subordinate CAs	Each region issues under its own subordinate beneath a shared root	Regional loss stops only that region's issuance	More CAs to rotate; consumers must trust the shared root	The stronger requirement below
DNS-only failover	Move the endpoint; no fence	Trivial	Split-brain issuance	Never for a signer

- IC4 stretch — stronger requirement
 - Per-region subordinate CAs under one root remove the single-writer promotion for leaf issuance
 - DR becomes "stop sending new work to the lost region".
 - Have the trusted root issue certificates for regional subordinate keys.
 - This is ordinary subordinate issuance
 - Cross-signing specifically adds an alternate issuer path.
 - The root and cross-region CRL signing stay single-writer, so the fenced promotion survives for them.
 - Revocation and pre-signing security intent already require independent durability in the baseline.
 - IC4 can extend RPO 0 to all lifecycle metadata if the stronger availability cost is acceptable.
- IC4 stretch — 10× load
 - 10M leaves and 2/s renewals raise log volume tenfold but not its shape.
 - Shard the metadata store by CA and ship each shard's log independently
 - The recovery point becomes a vector of positions.
 - Failover fetch bursts reach about 1,700/s
 - CDN and ETag absorb them and the API fleet still never sees them.
- IC4 stretch — cost and blast radius
 - The warm standby doubles storage and keeps a small compute footprint
 - The fencing authority is three tiny nodes.
 - Cell the control plane per region and per CA family so one bad promotion cannot move every tenant's writer at once.
 - Keep the restore-test cell permanent

- It is the cheapest insurance in the design.
- IC4 stretch — migration
 - Roll out observation of epoch-bearing requests first.
 - Drain all legacy writers and remove their direct signing credentials before claiming fencing.
 - Enable rejection only after every protected path enforces the grant.
 - Move consumers to disk-persisted caches before the first promotion drill so the drill measures continuity honestly.
- Weakest assumption
 - The weakest assumption is a tested vendor-supported path for the selected HSM key versions in the selected standby region.
 - Mitigation: pre-provision a root-issued regional subordinate and verify its chain on required consumers before the incident.
- Over-engineering warning
 - Do not build multi-master issuance for one CA
 - Two signers for one name is the incident, not the design.
 - Do not replicate everything synchronously to buy RPO 0
 - Issuance would then fail whenever either region is slow.

Level signal — IC3 baseline vs IC4 stretch

Phase	IC3 must land	IC4 adds	Separating signal
Requirements	RPO, RTO, key custody, handshake continuity as separate targets	Separate availability targets for handshakes, issuance, and emergency revocation	Refuses one RTO for three operations
Estimates	Data volume, replication lag, RTO budget by step	Shows the RTO is verification-bound, not copy-bound	A number moves budget from copying to verifying
Architecture	Warm standby, fencing authority, cached consumers, one trace	Names the fencing dependency's cost and the lease-length overlap	Every component has a mechanism and a price
Deep dive	Recovery point contents; restore test gates <code>READY</code> ; epoch fencing	Revocation union and orphan attribution across epochs during failback	Reasons across database, HSM, and artifact-store boundaries
Operations	Failure table, drills, observability	Migration order for the epoch check; permanent restore cell	Volunteers the drill and migration before being asked
Wrap	Recap and tradeoff	Names key recoverability as the weakest assumption first	Identifies the flaw before the interviewer does

Interview pushback and validation

- Q1: We already have nightly database backups
 - Why is that not disaster recovery?
 - **IC3 baseline**
 - The backup holds key handles, not keys
 - Without HSM key recoverability the restored CA cannot sign, so it is an inventory, not a recovery point.
 - **IC4 stretch**
 - Define `READY` as a passed restore test with a test signature per key version, and alarm when the newest `READY` point is older than 24 h.
- Q2: The primary region comes back an hour after promotion.
 - What happens?
 - **IC3 baseline**
 - Its lease expired and its epoch is stale
 - The store and the signing path reject its writes, so it is read-only by construction.
 - **IC4 stretch**

- Restore it from the standby's current point, reconcile orphans and revocations, then run a second fenced promotion to hand the writer back.
- Q3: Why not just switch DNS to the standby?
 - **IC3 baseline**
 - DNS moves new clients
 - It does not stop a partitioned primary from signing, so two issuers can exist for one CA.
 - **IC4 stretch**
 - The fence lives at the resource and the lease length is the maximum overlap
 - Wait it out before enabling issuance.
- Q4: The restored revocation table is older than the last CRL we published.
 - Is that a problem?
 - **IC3 baseline**
 - Restore the independent committed revocation ledger through the safe watermark.
 - Union published CRLs as an additional check
 - They cannot reveal unpublished revocations.
 - **IC4 stretch**
 - Extend independent durable replication to all metadata when the product requires complete RPO 0.
- Q5 (premise reversal): Why promote a region at all?
 - Give every region its own subordinate CA and make regional loss a non-event.
 - **IC3 baseline**
 - Agreed for leaf issuance
 - Per-region subordinates under a shared root turn regional DR into stopping new work at the lost region.
 - **IC4 stretch**
 - The root and cross-region CRL signing remain single-writer, so the fenced promotion shrinks rather than disappears.
- Q6: Can you give me RPO 0?
 - **IC3 baseline**
 - Only by making every issuance wait for a second region, which couples issuance availability to two regions.
 - **IC4 stretch**
 - Keep both revocations and pre-signing intents independently durable.
 - Extend full metadata replication only if the stronger requirement justifies it.
- Q7: A load balancer restarts during the outage with an empty disk.
 - What happens?
 - **IC3 baseline**
 - It cannot fetch a chain and cannot serve
 - Static stability breaks on boot, so last-known-good ships in the deploy artifact and the cache persists on disk.
 - **IC4 stretch**
 - Bundles and CRLs sit on replicated object storage behind a CDN, so even the fetch path survives control-plane loss.
- Validation scenarios
 - Restore a deliberately disabled historical key and preserve its state.
 - Fail READY if a required active signer is missing or unexpectedly disabled.
 - Promotion with a stale `expectedWriterEpoch`
 - `409` with no side effects.
 - Partition the primary, promote, then heal
 - The primary's writes must be rejected.
 - Restore with `published_generation` behind the last CRL
 - The published CRL must contain the union.

- Isolate surviving consumers for 24 h only when their cached certificate and status evidence has > 24 h remaining validity.
- Separately exercise near-expiry evidence and verify the declared failure policy.
- Consumer restart with an empty cache during the block
- Must serve from the shipped bundle.
- Failback after the standby issued and revoked
- Orphans inserted as REVOKED.
- Monthly drill measured against a 90 min target.

Recall card

- "A recovery point is a coordinated cut, and it is READY only after keys signed in the restore test."
- "Fence first, verify second, enable last; a restore never lowers the writer epoch."
- "Revocation only moves forward; union the last published CRL before you publish again."
- "Handshakes live on cached chains; new issuance and emergency revocation have their own availability targets."
- "DNS moves clients; the epoch check at the store and the signer is what stops a second issuer."
- Wrap-up script
 - "The design is a warm standby fed by log shipping and artifact replication, promoted through an independent fencing authority with a monotonic writer epoch."
 - "A recovery point is ready only after key and artifact verification, and promotion fences the old signer before opening the new one."
 - "Ordinary metadata remains asynchronous, while acknowledged revocation and pre-signing intent require independent durability."
 - "My weakest assumption is key recoverability, which I test in the selected standby region before relying on it."

References

- [Ranked question and report provenance.](#)
- [OCI role framing.](#)
- [Detailed API and schema companion.](#)
- Reference check: 2026-09-09.
 - Official documentation supports the mechanisms cited next to each link.
 - RPO, RTO, volumes, and the fencing design remain proposed interview assumptions.
- [OCI Certificates overview](#): regional service, CA hierarchy, Vault-backed CA keys, versioned rotation.
- [OCI Vault key overview](#): HSM-backed key custody and versions
 - Why a metadata backup is not a key backup.
- [OCI IAM policies](#): compartment-scoped authorization for restore cells and promotion operators.
- [RFC 5280](#): CRL number monotonicity and nextUpdate freshness bound.
- [OCI physical topology](#): availability and fault domains as documented vocabulary
 - The region-pair design above is proposed.
- [Multi-tenant CA sibling design](#): CA hierarchy, version state machine, serial policy.
- [Lease and fencing mechanics](#): fencing token checked at the resource.
- [PKI and KMS mechanism reference](#): key states, HSM signing, CRL freshness, cross-signing.